Mise en place du SSO pour le produit **AIRS Dossier**

Digitech

Version 2.0, 01/08/2019

Sommaire

1. Introduction . . . 2
2. Administration réseau . . . 3
3. Paramétrage et mise en œuvre pour Dossier . . . 4
3.1. Activation du filtre de servlet SPNEGO . . . 4
3.2. Vérification de la version **JAVA**. . . . 4
3.3. Nouvelle installation . . . 5
3.4. Mise à jour d'une installation . . . 5
3.5. Java Cryptography Extension (JCE) . . . 6
3.6. Fichiers de configuration Que ce soit dans le cadre d'une nouvelle installation ou de la mise à jour d'une installation existante, l'opération à réaliser doit être la même. . . . 6
3.7. Copie de fichiers . . . 6
3.8. Configuration de fichiers . . . 6
3.8.1. **params.xml** . . . 6
3.8.2. **sso.properties** . . . 6
3.8.3. **krb5.conf** . . . 7
3.8.4. **Login.conf** . . . 8
3.8.5. **Config.propertie** . . . 8
3.9. Activation Kerberos dans le navigateur des utilisateurs . . . 8
3.9.1. Internet Explorer . . . 8
3.9.2. Firefox . . . 8
4. Annexe Authenfication auprès d'un serveur Linux Kerberos MIT . . . 10
4.1. Sur le serveur . . . 10
4.2. Sur le poste client . . . 12
5. Erreurs courantes Failure unspecified at GSS-API level (Mechanism level: . . . 13

Table 1. Notes de suivi

Date	Version	Etat	Objet	Rédacteur	Validateur
02/11/2011	1.0	Validé	Création du document	Régis Krawezyk	
01/08/2019	2.0	En cours	Modification du document	Nicolas Félix	

1. Introduction

L'authentification unique (en anglais **S**ingle **S**ign-**O**n ou SSO) permet à un utilisateur de ne procéder qu'à une seule authentification pour accéder à son poste de travail ainsi qu'aux applications.

Sans SSO, à chaque accès à la page d'accueil de Dossier, l'utilisateur doit d'abord entrer ses **login** et **mot de passe**, que l'application utilise pour ouvrir une session Dossier.
Avec SSO, le navigateur transmet automatiquement à l'application le nom que l'utilisateur a saisi pour s'authentifier lors de l'ouverture de sa session Windows. Dès lors,l'application réceptionne le nom et vérifie sa validité auprès du serveur d'authentification,avant de l'autoriser ou non à accéder à l'application.

Ce document décrit le paramétrage nécessaire pour intégrer Dossier au sein d'un domaine géré par Active Directory (SSO de type Kerberos). En annexe est décrite la même procédure avec une authentification réalisée par un serveur Kerberos sous Linux.

Ce document se découpe en deux parties qui sont liées à deux types d'opérations distinctes nécessaires à la mise en œuvre de ce mode de fonctionnement.

- Prise en compte dans l'administration réseau
- Paramétrage et mise en œuvre sous Dossier

2. Administration réseau

Cette mise en œuvre nécessite la création par l'administrateur du réseau d'un compte utilisateur spécifique à l'application Dossier, sans expiration du mot de passe. Ici, nous appellerons ce service **$USER_AD_DOSSIER** (*dossier* par exemple).

Ensuite, il faut que ce compte **$USER_AD_DOSSIER** soit autorisé à se pré-authentifier auprès du serveur Active Directory pour vérifier la validité des tickets qui lui sont présentés. Pour cela, il est possible d'utilise l'utilitaire setspn (présent dans les supports tools de Microsoft) pour affecter à ce compte le statut de service principal name :

```
setspn.exe -A HTTP/$APP_SERVEUR $USER_AD_DOSSIER
setspn.exe -A HTTP/$APP_SERVEUR.$DOMAINE $USER_AD_DOSSIER
```

Ajouter tous les autres alias possibles pour ce service, c'est-à-dire les différents noms du serveur hébergeant l'application Dossier au sein du domaine. Il faut remplacer bien sûr :

- **$APP_SERVEUR**: par le nom du serveur qui contient le serveur d'applications Web au sein duquel est déployé l'application Dossier
- **$DOMAINE**: par le nom de votre domaine.
- **$USER_AD_Dossier**: par le nom du service choisi.

Pour la vérification des alias enregistrés, il suffit d'exécuter la commande :

```
setspn.exe -L dossier
```

Suite à cette opération, les URL du type ci-dessous pourront être protégées par le filtre d'authentification Kerberos de l'application *Web* :

```
http://$APP_SERVEUR:9090
http://$APP_SERVEUR:9090/dossier
http://$APP_SERVEUR.$DOMAINE:9090/
```

3. Paramétrage et mise en œuvre pour Dossier

Cette opération comporte plusieurs étapes qui peuvent être différentes selon que cette mise en œuvre concerne :

- Une nouvelle installation
- La modification d'une installation existante

Pour cette opération, il n'est pas nécessaire de disposer de droits d'administration comme pour le chapitre précédent sinon de bonnes connaissances des fichiers et paramètres de l'application Dossier.

3.1. Activation du filtre de servlet SPNEGO

SPNEGO est un filtre de *servlet* appelé par *apache-Tomcat* chaque fois que l'utilisateur tente d'accéder à une ressource protégée. Il utilise JAAS (**J**ava **A**uthentication and **A**uthorization **S**ervice) et Java GSS (**G**eneric **S**ecurity **S**ervices) pour la gestion du protocole Kerberos, et accepte ou rejette la requête suivant la validité du ticket Kerberos présenté par le navigateur.

Pour activer ce filtre, il faut :

- S'assurer de l'utilisation de la version **1.8** de **JAVA** compatible avec ce principe d'utilisation
- Copier et paramétrer des fichiers au sein de l'application Dossier déployée
- Activer l'utilisation du principe SSO au sein du navigateur

3.2. Vérification de la version JAVA.

Il suffit d'exécuter la commande suivante au sein d'une fenêtre de console ou d'un terminal.

```
java -version
```

Il est aussi possible de vérifier la présence d'une variable globale `JAVA_HOME` pointant vers le bon répertoire d'installation de Java (**clic droit sur le poste de travail › onglet Avancé › Variables d'environnement**).

Deux cas de figure se présentent selon que :

- Cette mise en place soit effectuée lors de la première installation du produit
- Cette mise en place soit réalisée dans le cadre d'une mise à jour d'un environnement existant

3.3. Nouvelle installation

Concernant ce cas de mise en œuvre, il suffit de suivre la description d'installation du produit tout en s'assurant d'utiliser une version 7 de **JAVA**. Cette version de **JAVA** est présente au sein du package d'installation.

3.4. Mise à jour d'une installation

Ce cas de mise en œuvre est différent dans la mesure où les installations sont classiquement basées sur d'une version de **JAVA** inférieure à 1.8.

Généralement, une installation du produit Dossier comprend les composants suivants :

- Serveur *Airs*
- Serveur *Full-Text*
- Serveur *Flowmind-WB2E*
- Serveur apache *Tomcat*
- Application Web Dossier

Plusieurs fichiers de configuration doivent être modifiés, comportant la référence au dossier d'installation de **JAVA**. En outre, les services Windows utilisant **JAVA** (ce qui concernent les serveurs *Full-Text*, *Flowmind-WB2E* et apache *Tomcat*) doivent être supprimés puis recréés après modification de leurs fichiers de configuration respectifs.

- Serveur **FTServeur**: Les deux fichiers de démarrage et d'arrêt proposés par défaut pour ce serveur contiennent les références au répertoire d'installation de **JAVA**. Il faut donc modifier ces dernières au sein de ces deux fichiers **startFtServer.bat** (ou **startFtServer.sh**), **shutDown.bat** (ou **shutDown.sh**). A noter que, spécifiquement aux environnements Windows, le fichier **wrapper.conf** contient la référence au répertoire d'installation de **JAVA**. Il faut donc aussi modifier ce fichier dans les cas où :
  - le fichier **FTserveur.bat** est utilisé pour le démarrage de ce serveur
  - ce serveur est démarré via le service **NT**
- Serveur **Flowmind-WB2E**: la modification de la référence à **JAVA** pour cette composante nécessite la modification des valeurs associées:
- à la variable **fm_java_bin** pour le fichier **profile.conf** présent au sein du sous-dossier **conf/** du répertoire d'installation de l'instance de processus
- à la variable **FM_JAVA_BIN** pour le fichier **fmconfigure.bat** (ou **fmconfigure** selon le type de plate-forme). Ces deux modifications ayant été effectuées, il est alors nécessaire d'exécuter le script **fmconfigure**, puis de recréer le **service NT** dans le cadre de l'utilisation de ce service.

> Si les scripts de suppression et de re-création du *service NT* n'existent pas, il est possible de modifier directement dans la base de registre le paramètre **JVM Library** de l'entrée Parameters du **service NT** (à rechercher par le nom du service).

- Serveur apache Tomcat: non présent par défaut au sein du fichier **catalina.bat** (ou **catalina.sh**), assurez-vous bien que si la variable d'environnement est redéfinie au sein de ce fichier, elle soit bien associée au répertoire d'installation de la version 1.8 de JAVA. Supprimez (paramètre *uninstall*) et recréez (paramètre *install*) le **service NT** via le script **service.bat** du répertoire *bin* (en lui passant l'agument).

3.5. Java Cryptography Extension (JCE)

Bien que présent par défaut dans les **jre** depuis la version **1.4**, il est toutefois possible de récupérer manuellement ce package. L'installation de la JCE consiste à déposer les fichiers **local_policy.jar** et **US_export_policy.jar** dans le répertoire /jre/lib/security de la **jdk**. Il faut bien sur faire coïncider la version de la **JCE** avec celle de la **JDK** (**jce8** pour JAVA *jdk* en version **8**).

3.6. Fichiers de configuration Que ce soit dans le cadre d'une nouvelle installation ou de la mise à jour d'une installation existante, l'opération à réaliser doit être la même.

Elle consiste en : * L'ajout de nouveau fichier de configuration * La modification de fichiers de configuration existants

3.7. Copie de fichiers

Il est nécessaire de copier les trois fichiers de configuration **login.conf**, **krb5.conf** et **sso.properties** dans le sous-répertoire **xml/** du répertoire de déploiement de l'application Web Dossier.

3.8. Configuration de fichiers

Cette étape de configuration concerne les fichiers suivants, tous présents dans le répertoire **xml/** (sous-répertoire de déploiement de l'application Web Dossier) :

3.8.1. params.xml

Une nouvelle balise est présente dans le fichier. Cette balise permet d'activer ou de désactiver le mécanisme utiliser pour la connection sso.

```
<!--  activation -->
<ssoActivated>true</ssoActivated>
<!--  désactivation -->
<ssoActivated>false</ssoActivated>
```

3.8.2. sso.properties

Seuls les paramètres susceptibles d'être modifiés apparaissent au sein du tableau ci-dessous.

Table 2. sso.properties

Variable
Valeur
spnego.allow.basic
Permet une authentification **HTTP** basique si le navigateur ne gère pas le protocole Kerberos. Par défaut, nous affectons cette valeur à true.
spnego.allow.localhost
Permet ou non une demande d'authentification provenant de localhost. Par défaut, nous affectons cette valeur à true.
spnego.allow.unsecure.basic
Combinée à l'option allowBasic, permet l'authentification **HTTP** basique même en l'absence du protocole **HTTPS**. Par défaut, nous affectons cette valeur à true.
spnego.preauth.password
Mot de passe utilisé par apache *Tomcat* pour consulter le serveur d'authentification (cf. compte **$USER_AD_DOSSIER** créé précédemment)
spnego.prompt.ntlm
Permet une authentification **HTTP** basique lorsque le navigateur essaie de s'authentifier au moyen du protocole de **NTLM** (ce dernier n'étant pas géré par le filtre de servlet). Par défaut, nous affectons cette valeur à true.
spnego.preauth.username
Login utilisé par apache *Tomcat* pour consulter le serveur d'authentification (cf. compte **$USER_AD_DOSSIER** créé précédemment)

Généralement, seuls les paramètres **password** et **username** sont modifiés.

3.8.3. krb5.conf

Placé au sein du sous-répertoire **xml/** du répertoire de déploiement de l'application Web Dossier, ce fichier contient les paramètres du serveur Kerberos.

```
[libdefaults]
default_realm = LOCALDOMAIN \
  default_tkt_enctypes = aes128-cts rc4-hmac des3-cbc-sha1 des-cbc-md5 des-cbc-crc \
  default_tgs_enctypes = aes128-cts rc4-hmac des3-cbc-sha1 des-cbc-md5 \
  des-cbc-crc permitted_enctypes = aes128-cts rc4-hmac des3-cbc-sha1 des-cbc-md5 des-
cbc-crc

[realms]
LOCALDOMAIN = { kdc = $KER_SERVEUR.$DOMAINE default_domain = $DOMAINE }

[domain_realm]
. $DOMAINE = LOCALDOMAIN
```

Il suffit de remplacer les paramètres **$DOMAINE** et **$KER_SERVEUR** respectivement par le nom du domaine et le nom complet du serveur Kerberos au sein du ***domaine***.

3.8.4. Login.conf

sans objet

3.8.5. Config.propertie

Activer ou ajouter la clé sso.type comme suis :

```
sso.type=SPNEGO
```

3.9. Activation Kerberos dans le navigateur des utilisateurs

Reste ensuite à autoriser l'utilisation de ce mode de fonctionnement au sein des divers navigateurs du client. En fonction de la version du navigateur, des sites déjà référencés, ce paramétrage peut ne pas être nécessaire. Il convient de réaliser un test sans avant de les ajouter.

3.9.1. Internet Explorer

Aller dans **Outils › Options Internet › Sécurité › Intranet local › Sites... › Avancé..** et indiquer le domaine **http://$DOMAINE** comme étant dans l'intranet.

3.9.2. Firefox

L'authentification Kerberos est activée par défaut pour les versions récentes de **Firefox**. Entrer `about:config` dans la barre d'adresse, et restreindre la liste des options en entrant **negotiate** dans le filtre de recherche rapide. Double-cliquer sur l'entrée **network.negotiate-auth.trusted-uris**, puis entrer **.$DOMAINE** pour limiter l'authentification Kerberos à ce *domaine*.

Cette entrée peut être laissée vide pour une autorisation sans restriction (non recommandée)

4. Annexe Authenfication auprès d'un serveur Linux Kerberos MIT

4.1. Sur le serveur

Installer les packages `krb5-libs`, `krb5-server` et `krb5-workstation`.

Editer les fichiers de configuration /etc/krb5.conf et /var/kerberos/krb5kdc/kdc.conf afin qu'ils reflètent le nom du domaine correct (dans le cadre d'un domaine simple, il suffit de remplacer **EXAMPLE.COM** et **example.com** en respectant la casse et de remplacer **kerberos.example.com** par le nom du serveur Kerberos).

Créer la base de données au moyen de la commande :

```
/usr/kerberos/sbin/kdb5_util create –s
```

Editer le fichier /var/kerberos/krb5kdc/kadm5.acl. Ce fichier est utilise par `kadmind` pour déterminer les personnes qui ont le droit d'administrer la base de données Kerberos et leur niveau d'accès. On peut se contenter de laisser une ligne unique (remplacer **EXAMPLE.COM**) :

```
*/admin@EXAMPLE.COM*
```

Créer le premier utilisateur par la commande (remplacer **username**) :

```
/usr/kerberos/sbin/kadmin.local -q "addprinc username/admin"
```

Lancer les services suivants par la commande :

```
/sbin/service krb5kdc start
/sbin/service kadmin start
```

Ajouter un par un chaque poste de travail du réseau (remplacer **pc-sso.digitech.lan** par le nom du poste au sein du réseau) :

```
addprinc -pw PASSWORD -e des-cbc-crc:normal host/pc-sso.digitech.lan
```

Ajouter chaque nouvel utilisateur autorisé à ouvrir une session par la commande (remplacer **L.LOGIN** par le login de l'utilisateur) :

```
addprinc -pw PASSWORD -e des-cbc-crc:normal L.LOGIN
```

Ajouter de la même manière un compte de pré-authentification pour l'application Dossier, dont nous reporterons les login et mot de passe dans le fichier **sso .properties** (cf. référence plus haut).

Editer le fichier /etc/krb5.conf qui doit refléter les paramètres du réseau (cf. référence plus haut, identique au fichier **krb5.conf** nécessaire au paramétrage de JAAS). Cette étape n'est pas nécessaire si les postes de travail sont situés sur le même domaine que le serveur.

Redémarrer Kerberos.

Vous trouverez des explications plus complètes à l'adresse suivante

4.2. Sur le poste client

Configurer Kerberos par les commandes suivantes au moyen de l'utilitaire `ksetup` qui fait partie lui-aussi des supports tools de Windows.

> Il faut remplacer respectivement **$DOMAINE**, **$KER_SERVEUR** et **$PASSWORD** au sein de l'exemple ci-dessous par:
>
> - le nom du domaine
> - le nom du serveur Kerberos
> - le mot de passe utilisé par apache {tomcat} pour consulter le serveur d'authentification (cf. compte dossier créé précédemment)

```
ksetup /setdomain $DOMAINE
ksetup /addkdc $DOMAINE $KER_SERVEUR.$DOMAINE
ksetup /setcomputerpassword $PASSWORD
```

rebooter

```
ksetup /mapuser * *
```

Vérifier que le nom du domaine de la machine a bien été modifié en ouvrant les **propriétés du poste de travail › Nom de l'ordinateur › Modifier › Autres**.

Décocher également l'option **Modifier le suffixe DNS principal**.

Créer le compte utilisateur correspondant à l'un des comptes déjà ouverts sur le serveur Linux. A partir de maintenant, l'utilisateur devrait être en mesure de s'authentifier en sélectionnant le bon domaine dans la liste déroulante lors de la prochaine ouverture de session Windows.

Vous trouverez des explications plus complètes à l'adresse suivante

5. Erreurs courantes Failure unspecified at GSS-API level (Mechanism level:

Encryption type AES256 CTS mode with HMAC SHA1-96 is not supported/enabled.

La configuration par défaut prévoit une clé aes de 128 (aes128-cts) il apparait ici un défaut de configuration car la clé du client est aes sur 256 bits . Il est donc nécessaire ici de faire évoluer la configuration de Dossier est de modifier dans le fichier krb5.conf présent dans le répertoire xml :

Listing 1. Configuration par défaut

```
[libdefaults]
default_realm = <CLIENT_REALM>
  default_tkt_enctypes = aes128-cts rc4-hmac des3-cbc-sha1 des-cbc-md5 des-cbc-crc
  default_tgs_enctypes = aes128-cts rc4-hmac des3-cbc-sha1 des-cbc-md5
  des-cbc-crc permitted_enctypes = aes128-cts rc4-hmac des3-cbc-sha1 des-cbc-md5 des-
cbc-crc
```

Listing 2. Nouvelle configuration

```
[libdefaults]
default_realm = <CLIENT_REALM>
  default_tkt_enctypes = aes256-cts aes128-cts rc4-hmac des3-cbc-sha1 des-cbc-md5 des-
cbc-crc
  default_tgs_enctypes = aes256-cts aes128-cts rc4-hmac
  des3-cbc-sha1 des-cbc-md5 des-cbc-crc permitted_enctypes = aes256-cts aes128-cts
rc4-hmac des3-cbc-sha1 des-cbc-md5 des-cbc-crc
```